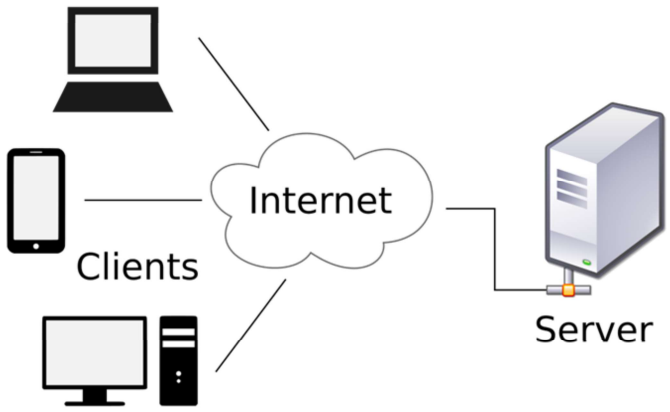
Server-based systems



© 2018 Al-Nafi. All Rights Reserved.

Server-based systems generally provide a specific purpose and may be specially configured or have special software loaded to provide a specific function. Typical types include: application servers, file servers, domain controllers, print servers, and network service servers (e.g., Domain Name Service). They are often centrally managed and controlled in most organizations and have limited access or functionality beyond their specific intended purpose. They are also often maintained in a controlled, limited access environment.

Server-based systems vulnerabilities

Vulnerabilities

- May be exposed to external communication/services
- Updates may be delayed due to operational need
- May exist for long periods (risk of being outdated)
- High-traffic volume makes monitoring more difficult

© 2018 Al-Nafi. All Rights Reserved.

Server-based systems vulnerabilities Mitigations

Mitigations

- Targeted network protections (server specific rules, restricted ports/protocols)
- Strong remote access mechanisms
- Configuration and change management
- Monitor: Logs, alerts-targeted to server functions

© 2018 Al-Nafi. All Rights Reserved.

Database Systems



© 2018 Al-Nafi. All Rights Reserved.

Database systems are hosted on various platforms to include stand-alone server, cloud hosting environments, distributed computing environments, and so on. Database systems inherit any platform vulnerabilities and add database-specific vulnerabilities. They typically contain large quantities of valuable information and require high-speed operation with large number of transactions. This tends to make database systems high-value targets for any attacker.

Database systems Vulnerabilities

Vulnerabilities

- Inference
- Aggregation
- Data Mining
- High Value target

© 2018 Al-Nafi. All Rights Reserved.

Inference: Attacker guesses information from observing available information. Essentially, users may be able to determine unauthorized information from what information they can access and may never need to directly access unauthorized data.

Aggregation: Aggregation is combining nonsensitive or lower sensitivity data from separate sources to create higher sensitivity information. For example, a user takes two or more publicly available pieces of data and combines them to form a classified piece of data that then becomes unauthorized for that user. Thus, the combined data sensitivity can be greater than the sensitivity of individual parts.

Data mining: Data mining is a process of discovering information in data warehouses by running queries on the data. A large repository of data is required to perform data mining. Data mining is used to reveal hidden relationships, patterns, and trends in the data warehouse. Data mining is based on a series of analytical techniques taken from the fields of mathematics, statistics, cybernetics, and genetics. The techniques are used independently and in

cooperation with one another to uncover information from data warehouses.

High value target: Databases are considered a high-value target and may be sought out by attackers and have attackers willing to spend greater effort to find technical vulnerabilities to exploit than other system types.

Database systems Mitigations

Mitigations

- Input Validation
- Robust authentication/access control
- Output throttling
- Anonymization
- Tokenization

© 2018 Al-Nafi. All Rights Reserved.

Input validation: User input or query input is carefully validated to ensure only allowable information is sent from the user interface to the database server. This limits the utility of Structured Query Language (SQL) injection type attacks and potentially protects database information
integrity from invalid entries.

Robust authentication/access control: Database access is strictly controlled and user interface is limited to preconfigured or controlled interface methods.
l Output throttling: To reduce an attacker's ability to siphon off database data one record at a time, throttling can be employed to limit the number of records provided over a specific time period. This limits an attacker's ability to perform data mining and some inference and aggregation attacks.

Anonymization: This approach permanently removes identifying data features from a database, typically to protect personal information.

Tokenization: Similar to anonymization except that information is replaced with an identifier that can be used to reconstruct the original data if necessary. The

identifiers (tokens) are then kept in a more secure system or offline. This approach also allows data to be shared or made available with less risk to inference and aggregation attacks.

Industrial Control Systems (ICSs) think nuclear plant and KESE or WAPDA



© 2018 Al-Nafi. All Rights Reserved.

We will cover this in a very detailed manner in stage 2 of the CODS track covering all topics and hands on exercises as they relate to SCADA.

Industrial systems and critical infrastructures are often monitored and controlled by simple computers called industrial control systems (ICS). ICSs are based on standard embedded systems platforms, and they often use commercial off-the-shelf software. ICSs are used to control industrial processes such as manufacturing, product handling, production, and distribution. They typically have components that execute on embedded, limited function hardware. They also typically contain interfaces between logical (computer) space and the physical world. These may include sensors, motors, actuators, valves, gauges, and so on.

Industrial Control Systems (ICSs) think oil and gas



© 2018 Al-Nafi. All Rights Reserved.

Industrial Control Systems (ICSs) Key elements

- Supervisory control and data acquisition (SCADA)
- Distributed control systems (DCSs)
- Programmable logic controllers (PLCs)

© 2018 Al-Nafi. All Rights Reserved.

Following are three well-known types of ICS systems:

Supervisory control and data acquisition (SCADA): A SCADA system can be typically viewed as an assembly of interconnected equipment used to monitor and control physical equipment in industrial environments. They are widely used to automate geographically distributed processes such as electricity power generation, transmission and distribution, oil and gas refining and pipeline management, water treatment and distribution, chemical production and processing, rail systems, and other mass transit.

Distributed control systems (DCSs): Typically confined to a geographic area or specific plant (e.g., manufacturing facility). They are characterized by large numbers of semi-autonomous controllers. They share many similarities with SCADA systems, but they are typically confined to a defined area with a local control center.

Programmable logic controllers (PLCs): Ruggedized industrial controller. Typically use specialized code that reacts in real time to inputs. May be stand-alone systems or included as components in SCADA or DCS infrastructure.

Industrial Control Systems (ICSs) Vulnerabilities

- **Limited functionality:** Standard OS functions and protections may not be available.
- **Limited protections:** General purpose host protections are not feasible.
- **Long lifespan (become outdated):** Typically in operation for 10+ years.
- **Susceptible to misuse/error:** Complicated, specialty systems, difficult to validate correct code and configuration.
- **Highly susceptible to denial of service (DoS) attacks:** Typically contain minimal communication protections and are very sensitive to improper input.
- **Attacks can produce physical effects:** Unlike most computing systems, attacks can cause impacts to the physical world.
- **Often unattended in remote locations:** Physical security may be limited or unmonitored allowing attackers to gain and maintain physical access with limited effort.

© 2018 Al-Nafi. All Rights Reserved.

Industrial Control Systems (ICSs) Mitigations

- **Isolated network infrastructure:** The most effective mitigation is to ensure limited functionality components are not connected or exposed to general purpose networks and are only connected to high controlled networks.
- **Robust network connection restrictions and monitoring:** Any connections allowed on or off control system networks must be carefully monitored.
- **Highly segmented network:** Networks segmented by process or by devices that must directly communicate to function. This generates some very small network segments, but is highly desirable.
- **Protect communication channels:** All communication channels must be heavily protected from outside access.
- **Robust configuration control:** Configuration and code on devices must be robustly managed.

© 2018 Al-Nafi. All Rights Reserved.